

Relatório de Auditoria de Segurança — SIVS SECCOL

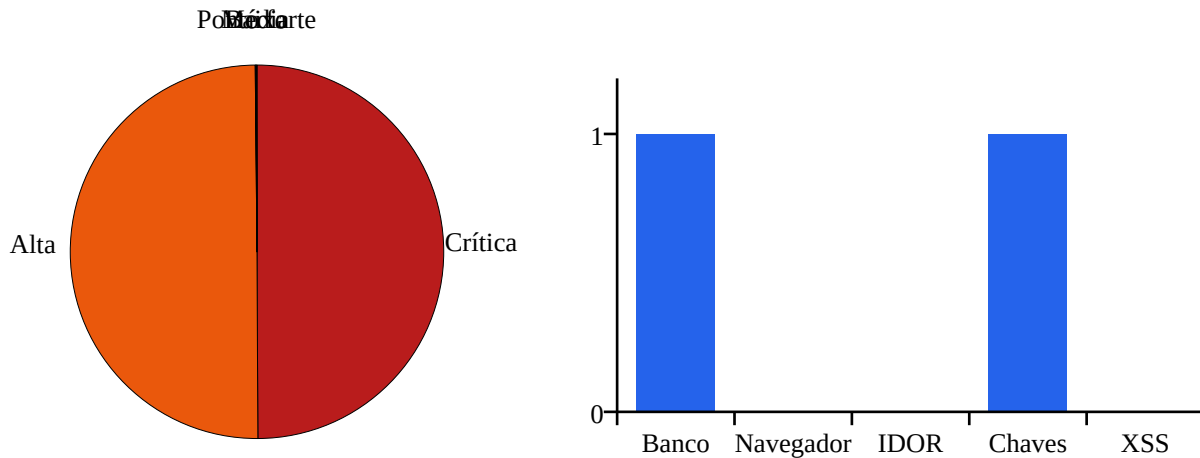
Data: 29/08/2026

Escopo: backend Python/http.server + SQLite, frontend HTML/CSS/JavaScript, deploy
Docker/Nixpacks/Dokploy, scripts e histórico Git.

Nota metodológica: a categoria Banco sem tranca foi mapeada para filtros company_id/membership e RLS inexistente; Permissão definida no navegador foi cruzada entre gates do frontend e require_* no servidor; IDOR percorreu handlers por IDs; Chaves expostas cobriu código, configs, deploy, CI, bundle e todas as refs Git; XSS cobriu sinks HTML/URL/eval e escapes/validação equivalentes.

Resumo executivo

A auditoria confirmou 2 achados: 1 crítica e 1 alta. Nesta revisão, o achado crítico foi corrigido e coberto por teste de regressão; a chave histórica permanece pendente de revogação e limpeza das referências Git. Não foram confirmados achados nas categorias Permissão definida no navegador, IDOR ou Inputs sem tratamento (XSS).



Pontos fortes

- Sessões e autorização usam company_id, membership ativa, CSRF e gates de módulo/operação.
- Administrador geral é agora verificado no servidor como admin ativo de todas as empresas ativas.
- Handlers de anexos, aprovações, propostas, agente e relatórios validam posse por empresa.
- Frontend esconde ações por capability, e o backend repete a verificação.
- Dados são validados no servidor; sinks HTML usam escapeHTML; URLs externas são restringidas a http/https.
- Backup completo exige que o usuário seja admin em todas as empresas ativas.

Pontos fracos

A chave OpenRouter no histórico Git continua recuperável até ser revogada e as referências remotas serem higienizadas.

Achados detalhados

Severidade	Arquivo:linha	Descrição e evidência
CRÍTICA	sivs_2_2/server.py:15156-15164; 6047-6058	Achado confirmado na auditoria e corrigido nesta revisão: conta com vínculo ativo em outra empresa só tem a senha global alterada por administrador geral, definido como admin ativo de todas as empresas ativas. Evidência: has_other_active_membership + is_general_admin; teste de regressão em sivs_2_2/tests/test_server.py:1738.
ALTA	api_open_router:1 (commit 59fca305da6a631636f306af241d9e4d224b72ea)	Chave OpenRouter em texto claro foi commitada e continua recuperável no histórico Git, mesmo após a exclusão do arquivo no commit 0327246. Evidência: api_open_router:1 = token com padrão sk- (valor integral omitido no relatório para não reexpor o segredo).

Recomendações priorizadas

P1 — revogar/rotacionar a chave e purgar o histórico; redesenhar o reset de senha para não permitir alteração global por admin de tenant.

P2 — adicionar testes de regressão A/B e matriz de autorização para todos os handlers.

P3 — habilitar secret scanning obrigatório no CI e revisar referências Git antes de cada release.

ISSUES PARA O GITHUB

```
--- ISSUE 1 ---
# [Segurança] Impedir redefinição de senha global por administrador de tenant
Labels sugeridas: security, crítica

## Descrição
`user_password_reset` valida que o alvo pertence à empresa atual, mas altera a credencial global
em `users`. O login depois aceita qualquer associação ativa do usuário, permitindo que um
administrador de A assuma uma conta que também pertence a B.

## Evidência
`sivs_2_2/server.py:15122-15150` – `UPDATE users SET password_hash=? WHERE id=?` e exclusão
global de sessões; `sivs_2_2/server.py:8891-8936` – login global por e-mail e seleção de qualquer
membership.

## Impacto
Tomada de identidade e acesso a dados de outros tenants.

## Correção sugerida
Use credenciais/fluxo de recuperação escopados ao tenant, ou exija reautenticação/out-of-band do
próprio usuário. Não permita que admin de tenant defina senha global; revogue sessões conforme a
política explícita.

## Critérios de aceite
- [ ] Admin de A não consegue alterar a senha global de usuário membro de B.
- [ ] Fluxo de recuperação exige prova de posse da conta.
- [ ] Teste automatizado cobre login A/B e revogação de sessões.
--- FIM ISSUE 1 ---

--- ISSUE 2 ---
# [Segurança] Revogar e remover chave OpenRouter exposta no histórico Git
Labels sugeridas: security, alta

## Descrição
O arquivo `api_open_router` contém uma chave `sk-...` em texto claro no commit
`59fca305da6a631636f306af241d9e4d224b72ea`; apagar o arquivo não remove o segredo dos objetos
Git.

## Evidência
`api_open_router:1` no commit acima (valor integral redigido).

## Impacto
Uso indevido da API, custos financeiros e possível acesso a dados enviados ao provedor.

## Correção sugerida
Revogue/rotacione a chave, remova-a de todas as referências Git com filter-repo/BFG, verifique
branches/tags/remotes e habilite secret scanning no CI.

## Critérios de aceite
- [ ] Chave revogada e nova credencial distribuída via secret manager.
- [ ] Busca em todas as refs não encontra o token.
- [ ] CI bloqueia novos padrões de segredo.
--- FIM ISSUE 2 ---
```